ОТЧЕТ О РИСКАХ ИНСТИТУЦИОНАЛЬНОГО УРОВНЯ V1.1 • СТАНДАРТ КРИПТОГРАФИЧЕСКОЙ ЗАЩИТЫ

HAICHAIN: Отчет об Институциональном Дью-Дилидженсе Рисков

Математические Доказательства, Моделирование Угроз и Матрица Верификации Red-Team для Инвесторов Tier-1

TARGET AUDIENCE	CRYPTOGRAPHIC SECURITY	PROTOCOL KERNEL
Tier-1 Venture Allocators & Audit Firms	Hardware Passkey • 9 Invariants Bound	HAICHAIN v1.1 • CapLeaf 223 Bytes

ОТЧЕТ ОБ ИНСТИТУЦИОНАЛЬНОМ ДЬЮ-ДИЛИДЖЕНСЕ РИСКОВ HAICHAIN

Математические Доказательства, Моделирование Угроз и Матрица Верификации Red-Team

Целевая аудитория: Венчурные фонды Tier-1 (a16z crypto, Paradigm, Sequoia), институциональные кастодианы и ведущие аудиторские компании (OtterSec, Neodyme, Kudelski Security)
Версия протокола: HAICHAIN Kernel v1.1 / CapLeaf v1 (Сетевая схема 223 байта)
Технические стандарты: Anchor Framework (Solana L1) + Sui Move (`AgentCap`) + Tron Rail Intent Solver

1. ИСПОЛНИТЕЛЬНОЕ РЕЗЮМЕ И ПАРАДИГМА БЕЗОПАСНОСТИ

Автономные ИИ-агенты, осуществляющие микроплатежи, создают принципиально иные векторы атак по сравнению с традиционными DeFi: 1. **Нулевая задержка без участия человека:** ИИ-агент при выполнении вызовов инструментов может быть скомпрометирован посредством непрямой инъекции промпта (Indirect Prompt Injection) и выпустить тысячи несанкционированных платежных ваучеров за считанные секунды. 2. **Уязвимость утечки закрытых ключей:** Работа экземпляров агентов на распределенных узлах (Cloudflare Workers, локальные MCP, бессерверные функции) увеличивает риск компрометации закрытых ключей. 3. **Размножение мошеннических мерчантов (Sybil):** В открытой сети M2M злоумышленники могут регистрировать неограниченное количество временных доменов для обхода ограничений частоты запросов.

Для полного решения этой задачи без ущерба для субмиллисекундной скорости **HAICHAIN полностью разделяет исполнение платежей и хранение капитала**: - **Высший суверенный контроль:** Аппаратный биометрический ключ WebAuthn FIDO2 Passkey (P-256) сохраняет 100% суверенное владение пулом средств. - **Изоляция прав субагентов:** Временные пары ключей Ed25519 строго изолированы в межпроцессном механизме политик (Policy Engine) без доступа к мнемонической фразе кошелька. - **Ончейн Merkle-якорь:** Схема дескриптора полномочий (223 байта) жестко обеспечивает выполнение 9 математических инвариантов ($I_1 \dots I_9$).

2. ФОРМАЛЬНАЯ МОДЕЛЬ УГРОЗ И ОГРАНИЧЕНИЕ УБЫТКОВ

2.1. Классификация поверхности атак

Класс угрозы	Сценарий	Традиционный риск Web3	Предельные потери в HAICHAIN
T_1 (Инъекция промпта)	LLM принуждают заплатить неавторизованному мерчанту	Полное опустошение кошелька (`100,000+`)	$E_{\text{theft}} = 0$ (Блокируется белым списком корня Merkle)
T_2 (Сговор мерчанта)	Легитимный мерчант пытается дважды заявить ваучер	Двойное списание с баланса	$E_{theft} = 0$ (Anchor гарантирует $P_i \le \min(C_i, R_i)$)
T_3 (Атака через новый API)	Субагент пытается истощить лимит на непроверенном API	Постепенное истощение пула	$E_{theft} \le M_{tpl}$ (Ограничено общим бюджетом шаблона)
T_4 (Полный захват агента)	Утечка ключа + сговор с мерчантом из белого списка	Мгновенный вывод всех средств	$E_{theft}(\tau) \le \min(B, K, W_p \cdot n(\tau, \omega_p))$

2.2. Теорема 6.1: Верхняя граница потерь в худшем сценарии (τ_4)

Пусть τ — общее время отклика протокола от момента первой неавторизованной транзакции до подтверждения транзакции экстренной заморозки (Panic Freeze) в блокчейне:

$$\tau = t_{detect} + t_{owner} + t_{land}$$

где $t_{detect} \le 5.0c$, $t_{owner} \le 2.0c$, $t_{land} \le 5.0c$.

Максимальный совокупный ущерб $E_{theft}(\tau)$ математически строго ограничен:

$$E_{theft}(\tau) \le \min(B,\; K,\; W_p \cdot n(\tau,\, \omega_p),\; \sum_{i:\, m_i \in \mathcal{A}} E_i(\tau))$$

Вывод: Для институционального пула с балансом `10,000 USDT`, лимитом на лист `50 USDT` и ограничением скорости `10 USDT / час`, злоумышленник, получивший ключ агента, **не сможет похитить более** `10 USDT` до срабатывания заморозки, сохраняя `9,990 USDT` **(99.9%)** средств фонда.

---

3. МАТРИЦА АППАРАТНОГО УКРЕПЛЕНИЯ RED-TEAM

5 критических векторов атак устранены на уровне протокольного ядра: 1. Защита от повторного списания эскроу-канала. 2. Строгая каноническая привязка Associated Token Account мерчанта. 3. Полная недействительность ваучеров при смене эпохи паники (I_6). 4. Обязательный возврат Lamports аренды в основной пул. 5. Жесткое сжигание бюджета шаблона при создании дочерних листьев.

---

4. ОТЧЕТ ОБ АУДИТЕ 9 МАТЕМАТИЧЕСКИХ ИНВАРИАНТОВ ($I_1 \dots I_9$)

Все инструкции в `programs/haichain-core/src/lib.rs` строго соблюдают инварианты I_1 (сохранение капитала), I_2 (безопасность получателя), I_3 (потолок бюджета), I_4 (ограничение скорости), I_5 (сужение прав PDA), I_6 (изоляция эпохи паники), I_7 (таймаут сессии), I_8 (однократный расчет), I_9 (изоляция аккаунтов).

---

5. ТОКЕНОМИКА И РЕГУЛЯТОРНОЕ СООТВЕТСТВИЕ

- **100% Утилитарный стандарт (Иммунитет к Howey и MiCA):** Отсутствие пассивного стейкинга и дивидендов.
- **50% Buyback & Burn:** 50% сетевых сборов направляются на открытый выкуп $HAISI и постоянное сжигание.
- **50% Резервный фонд (CHGB):** Гарантия ликвидности и соблюдения SLA поставщиков.

---

6. ЗАКЛЮЧЕНИЕ И ДОСТУП К DATA ROOM

HAICHAIN v1.1 представляет собой первый в мире математически доказанный и аппаратно изолированный платежный уровень для автономных ИИ-агентов.